11 Security: Authentication and SPA

This chapter covers

- Understanding the Spring Security fundamentals
- Managing user accounts with Keycloak
- Working with OpenID Connect, JWT, and Keycloak
- Authenticating users with Spring Security and OpenID Connect
- Testing Spring Security and OpenID Connect

Security is one of the most critical aspects of web applications and probably the one with the most catastrophic effects when done wrong. For educational purposes, I'm introducing this topic only now. In a real-world scenario, I recommend considering security from the beginning of each new project or feature and never letting it go until the application is retired.

Access control systems allow users access to resources only when their identity has been proven and they have the required permissions. To accomplish that, we need to follow three pivotal steps: identification, authentication, and authorization.

1. *Identification* happens when a user (human or machine) claims an identity. In the physical world, that's when I introduce myself by stating my name. In the digital world, I would do that by providing my username or email address.